

GRC Portfolio - Recruiter Quick View

Fast index of work samples, analyst skills, and frameworks demonstrated

Work sample	Core skills demonstrated	Framework / method
Security Risk Assessment	Risk identification, scoring, treatment, residual risk, executive summary	NIST CSF / RMF concepts
Risk Register	Ownership, treatment, status, review cadence, accountability	Enterprise risk management
Vulnerability Assessment	Risk-based prioritization, SLA, remediation, validation	CVSS-informed methodology
PASTA Threat Model	Attack paths, threats, vulnerabilities, business impact, controls	PASTA
Security Policy Drafts	Policy language, scope, requirements, exceptions, enforcement	NIST / ISO themes
Access Control Assessment	RBAC, MFA, least privilege, SoD, lifecycle reviews	NIST AC/IA; IAM practices
Data Leak Risk Analysis	Data flows, DLP, encryption, monitoring, response	NIST SP 800-53
Compliance Readiness	Evidence review, control gaps, remediation, audit readiness	SOC 2 / PCI DSS / GDPR / ISO
Botium Toys Case Study	End-to-end risk assessment and prioritized roadmap	Multi-control case study

Target Role Alignment

- **GRC Analyst:** Strongest alignment - risk registers, controls, evidence, remediation, policy, compliance, and governance.
- **IT Risk Analyst:** Strong alignment - inherent/residual risk, ownership, treatment decisions, review cadence, and reporting.
- **Security Compliance Analyst:** Strong alignment - control mapping, evidence expectations, gaps, remediation, and readiness tracking.
- **Cybersecurity / Information Security Analyst:** Strong supporting evidence - IAM, vulnerability management, data protection, incident readiness, and risk communication.

Interview-Defensible Positioning

- All scenarios are clearly presented as portfolio work samples or case studies rather than claims of performing audits for an employer.
- Frameworks are used to organize analysis; the work does not claim formal certification, attestation, or legal compliance.
- Recommendations include ownership, evidence, validation, and residual-risk thinking to reflect practical analyst responsibilities.